

Identification and Authentication (3.5) Family

Security Requirements and the Technologies That Implement Them

A practitioner reference for Defense Industrial Base contractors · Family 5 of 14 in a 14-part series on the NIST SP 800-171 families · Prepared July 2026

Overview of the Identification and Authentication Family

Identification and Authentication (3.5) answers two questions for every actor that touches the system: **who or what are you** (identification), and **can you prove it** (authentication). Where Access Control (3.1) decides what an identity may do, this family guarantees the identity itself is genuine - for users, for processes acting on their behalf, and for devices. Every downstream control that keys off identity - least privilege, audit accountability, session control - is only as trustworthy as the authentication that anchors it.

The family contains **11 security requirements - 2 Basic** (from FIPS 200) and **9 Derived** (from NIST SP 800-53). It carries an outsized share of scoring weight: four requirements (3.5.1, 3.5.2, 3.5.3, and 3.5.10) are worth **5 points each**, and in DIBCAC assessments Identification and Authentication is consistently among the **most-failed families** - most often because multifactor authentication is not deployed to every required account and access path, or because authenticators and password handling are not FIPS-validated. This is **Family 5 of 14** in a planned series covering all fourteen 800-171 families.

5-point requirements cannot ride on a POA&M. Under the CMMC assessment rules, only 1-point deficiencies are eligible for a Plan of Action and Milestones at assessment time (the sole exception is 3.13.11, scored at 3 points when encryption is employed but not FIPS-validated), and a conditional status still requires a minimum score. The four 5-point requirements in this family - 3.5.1, 3.5.2, 3.5.10, and especially MFA under 3.5.3 - must be **fully implemented before the assessment**. An MFA gap discovered during the assessment is, in practice, a failed assessment.

Which revision applies? This guide covers **NIST SP 800-171 Revision 2**, which is the baseline the DoD's CMMC program and DFARS 252.204-7012 currently require. Revision 3 has **not** been adopted for CMMC as of this writing - continue to assess against Revision 2 until the DoD formally transitions.

Requirement wording below is **summarized for readability**. The controlling text is the official publication, **NIST SP 800-171 Rev 2** (security requirements) and **NIST SP 800-171A** (assessment

objectives); consult them for exact language. SPRS point values are per the **DoD Assessment Methodology** (NIST SP 800-171 DoD Assessment Methodology, Version 1.2.1).

The 11 Identification and Authentication Requirements and Expected Evidence

The evidence column lists the artifacts an assessor typically expects; most controls need **both** a written policy and a technical artifact. The figure under each control ID is its **SPRS point value** (5, 3, or 1) - the score deducted if the control is not met.

NIST SP 800-171 Rev 2 Identification and Authentication (3.5) requirements, SPRS weight, and expected evidence.

Control	Security Requirement	Evidence / Artifacts an Assessor Expects
3.5.1 5 pts	Identify system users, processes acting on behalf of users, and devices.	An identification and authentication policy; a documented naming convention for unique identifiers; a directory export showing every user, service account, and device has exactly one identifier of its own; records showing each device has its own identity as well - a machine certificate issued to it, or the device object created in the directory when it is joined
3.5.2 5 pts	Authenticate (or verify) the identities of users, processes, or devices as a prerequisite to allowing access to organizational systems.	The identity provider's authentication-method configuration; evidence that no anonymous or shared logons exist anywhere in scope; documentation of how service-account credentials are managed; the 802.1X or certificate configuration that makes devices authenticate before connecting
3.5.3 5 pts†	Use multifactor authentication for local and network access to privileged accounts and for network access to non-privileged accounts.	An export of the Conditional Access or MFA policy proving it covers every user and every access path (not just remote access); a per-user MFA registration report showing who is actually enrolled; an inventory of the authenticators in use (FIDO2 keys, smart cards, Windows Hello for Business); evidence that MFA also covers local logons to privileged accounts
3.5.4 1 pt	Employ replay-resistant authentication mechanisms for network access to privileged and non-privileged accounts.	Configuration showing replay-resistant protocols (Kerberos, TLS, FIDO2) carry the authentication traffic; evidence that NTLMv1 and other legacy protocols are disabled; a Conditional Access policy requiring phishing-resistant methods for administrators
3.5.5 1 pt	Prevent reuse of identifiers for a defined period.	An identifier-management procedure stating how long a departed user's identifier is held before it can ever be reissued; provisioning-system configuration showing separated accounts are disabled and retained rather than deleted and recycled; records proving the onboarding/offboarding process runs each time - helpdesk tickets,

Control	Security Requirement	Evidence / Artifacts an Assessor Expects
		completed offboarding checklists, or automated provisioning logs from hires and separations
3.5.6 1 pt	Disable identifiers after a defined period of inactivity.	A policy defining the inactivity threshold (e.g., 60 days); output from a scheduled report or script that lists accounts by last-logout date; records showing accounts that crossed the threshold were actually disabled
3.5.7 1 pt	Enforce a minimum password complexity and change of characters when new passwords are created.	An export of the domain or cloud password policy showing the enforced length and complexity rules; the banned-password-list or password-protection configuration that rejects weak and reused patterns at change time; any stricter fine-grained policies applied to admin or service accounts
3.5.8 1 pt	Prohibit password reuse for a specified number of generations.	A policy export showing the enforced password-history setting - how many previous passwords the system remembers and refuses to accept again (24 is the common benchmark value)
3.5.9 1 pt	Allow temporary password use for system logons only with an immediate change to a permanent password.	The onboarding and password-reset procedure showing first-use credentials are temporary; evidence the "user must change password at next logon" flag is set on new and reset accounts; if Temporary Access Pass is used, its configuration showing passes are time-limited and one-time
3.5.10 5 pts	Store and transmit only cryptographically-protected passwords.	Evidence passwords are stored only as salted hashes - reversible encryption off, no legacy LM hashes; configuration forcing authentication traffic over encrypted channels (TLS, LDAPS); the FIPS-mode setting enabled on endpoints; documentation that any password vaults encrypt their contents
3.5.11 1 pt	Obscure feedback of authentication information during the authentication process.	Demonstration that password entry is masked on operating-system and application logons; the policy setting that disables the password-reveal button where required; verification that in-house and legacy applications also mask credentials and never echo them in errors, URLs, or logs

2 Basic requirements (3.5.1-3.5.2) and 9 Derived requirements (3.5.3-3.5.11). † The DoD Assessment Methodology scores 3.5.3 on a sliding scale: 5 points are deducted if MFA is absent, but only 3 points if MFA is implemented for remote and privileged users yet not for general (non-privileged network) users.

Implementing Technologies and How to Configure Them

The systems below are the common building blocks for the family. A single well-designed identity architecture - one directory, phishing-resistant MFA, a modern authentication stack, and

automated identifier lifecycle - satisfies most of the family at once.

Identity Provider / Directory (Microsoft Entra ID, Active Directory)

- Make one directory authoritative for every user, service account, and device; assign each a unique identifier under a documented naming convention (e.g., `jdoe`, `svc-backup`, `WKS-ENG-014`). No shared or generic accounts on CUI systems. (3.5.1, 3.5.2)
- In hybrid environments, sync AD to Entra ID with Entra Connect and use Conditional Access as the single policy chokepoint for authentication requirements. (3.5.2, 3.5.3)
- Register every process identity explicitly: managed identities or service principals in Azure, gMSAs (group Managed Service Accounts) on-premises - never a human account running a scheduled task. gMSAs also remove the human-managed password entirely. (3.5.1, 3.5.2, 3.5.10)
- Establish device identity via Entra join / hybrid join or 802.1X machine certificates so devices authenticate before users do. (3.5.1, 3.5.2)

Multi-Factor Authentication (the 5-point core of the family)

- Scope MFA to **all three** populations 3.5.3 names: local access to privileged accounts, network access to privileged accounts, and network access to non-privileged accounts. The common failure is covering remote access only - 800-171A objectives require MFA on internal (network) access too. (3.5.3)
- Enforce via Entra Conditional Access (or Cisco Duo or Okta for hybrid apps) with no per-app opt-outs; use authentication-strength policies to require phishing-resistant methods for administrators. (3.5.3, 3.5.4)
- Cover **local** privileged access: Windows Hello for Business or smart card / FIDO2 logon on servers and workstations where admins sign in interactively; for network equipment, MFA at the RADIUS/TACACS+ front end (e.g., Cisco ISE + Duo). (3.5.3)
- Note the CMMC-relevant nuance on authenticator strength: FIPS 140-validated cryptography applies wherever cryptography protects the authentication (3.13.11 flows in here). Hardware authenticators such as the **YubiKey 5 FIPS Series** and Windows Hello for Business backed by a FIPS-validated TPM give the cleanest evidence trail. (3.5.3, 3.5.10)
- Avoid SMS and voice factors; they are weak against phishing and SIM-swap. Prefer FIDO2 security keys, platform passkeys (device-bound), Windows Hello for Business, or at minimum number-matched push in Microsoft Authenticator. (3.5.3, 3.5.4)

Replay-Resistant Authentication (Kerberos, TLS, FIDO2)

- Modern defaults already carry this control: Kerberos (authenticator timestamps and one-time session keys), TLS 1.2+ channels, and FIDO2/WebAuthn (per-ceremony challenge signing) are all replay-resistant. The work is disabling what is not. (3.5.4)

- Disable NTLMv1 and LM outright (GPO *Network security: LAN Manager authentication level* = "Send NTLMv2 response only. Refuse LM & NTLM"); audit and restrict remaining NTLMv2 use with NTLM auditing. (3.5.4, 3.5.10)
- Disable legacy/basic authentication in Exchange Online and block legacy-auth clients via Conditional Access - basic auth replays a static credential on every request. (3.5.4)
- Require SMB signing and LDAP signing / channel binding to defeat relay-style replay on internal protocols. (3.5.4)

Password Policy Enforcement (GPO, Entra Password Protection)

- Set domain password policy in line with your SSP: minimum length (14+ characters is a common DIB target), complexity, and history of 24 remembered passwords. Use AD fine-grained password policies for stricter service-account and admin tiers. (3.5.7, 3.5.8)
- Deploy **Entra Password Protection** (cloud and on-prem agents on domain controllers) to ban weak and custom-listed passwords at change time - this is strong "change of characters" and complexity evidence. (3.5.7)
- Issue first-use and reset credentials as one-time values: check "user must change password at next logon," or better, use an Entra **Temporary Access Pass** (time-limited, one-time) to bootstrap passwordless enrollment. (3.5.9)
- Never enable "store passwords using reversible encryption"; confirm it is disabled domain-wide. (3.5.10)

Cryptographic Protection of Credentials (FIPS mode, LDAPS, vaults)

- Enable the Windows FIPS security-policy setting (*System cryptography: Use FIPS compliant algorithms*) on CUI-handling endpoints and servers, and document the FIPS 140 certificate numbers of the modules in use (e.g., Windows CNG). (3.5.10)
- Force LDAPS / LDAP signing for directory binds, HTTPS for all web authentication, and RADIUS with EAP-TLS rather than PAP so passwords never cross the wire in cleartext. (3.5.10)
- Store break-glass, local-admin, and service credentials only in encrypted vaults: Microsoft LAPS (Windows LAPS rotates and encrypts local-admin passwords into AD/Entra), Azure Key Vault, HashiCorp Vault, or a PAM vault (CyberArk, Delinea, BeyondTrust). (3.5.2, 3.5.10)

Identifier Lifecycle Management (onboarding, role changes, offboarding)

- Drive provisioning and deprovisioning from the HR system of record (SCIM provisioning from Workday/BambooHR into Entra ID, or Entra ID Governance lifecycle workflows) so accounts are created, changed, and disabled on event, not on memory. (3.5.1, 3.5.5, 3.5.6)
- On separation, **disable** the account and retain it for the documented non-reuse period rather than deleting it - deletion invites identifier recycling and breaks audit attribution. (3.5.5)

- Automate inactivity handling: a scheduled job (Graph or `Search-ADAccount - AccountInactive`) that reports and disables accounts past the SSP-defined threshold (commonly 35-90 days), with the run output retained as evidence. (3.5.6)

Obscured Authentication Feedback

- Operating systems and mainstream IdPs mask password entry by default; the assessment risk is in-house and legacy applications - verify each CUI-relevant app masks credentials and does not echo them in errors, URLs, or logs. (3.5.11)
- Where a "show password" toggle exists, it is generally acceptable as a deliberate user action; document that position in the SSP rather than leaving it unaddressed. (3.5.11)
- Ensure error messages do not disclose which element failed ("invalid username or password," not "unknown user"). (3.5.11)

Network and Device Authentication (802.1X / RADIUS / Certificates)

- Issue machine certificates via Intune SCEP/PKCS or AD Certificate Services and require EAP-TLS 802.1X for wired and wireless access, so only identified, authenticated devices reach the CUI VLANs. (3.5.1, 3.5.2)
- Authenticate administrators to network devices through a central AAA service (Cisco ISE, Aruba ClearPass, RADIUS/TACACS+) tied to the directory and MFA - no shared local device logins. (3.5.2, 3.5.3)

Tools for Extracting Structured Configuration Evidence

Wherever possible, capture evidence as **structured, text-based exports** - JSON, XML, CSV, INF, XCCDF, or OSCAL - rather than screenshots. Machine-readable exports are timestamped, show the full setting, and can be ingested directly by a compliance platform.

Microsoft Entra ID / Microsoft 365 (identity, MFA, Conditional Access)

- **Microsoft Graph PowerShell SDK** - `Get-MgUser` , `Get-MgIdentityConditionalAccessPolicy` , and the authentication-methods endpoints export users, MFA registration state, and Conditional Access policies as JSON/CSV. (3.5.1, 3.5.2, 3.5.3)
- **Authentication Methods Activity report** / `Get-MgReportAuthenticationMethodUserRegistrationDetail` - per-user registered factors, exportable to CSV; the definitive "who actually has MFA" artifact. (3.5.3)
- **Microsoft365DSC** - exports the full tenant configuration (Conditional Access, authentication methods policy, password protection) as declarative, version-controllable text. (*broad IA coverage*)

- **CISA ScubaGear** - automated assessment of M365/Entra secure-configuration baselines, including MFA and legacy-auth checks, output as JSON plus a readable report. (3.5.3, 3.5.4)

Windows / Active Directory / Group Policy

- **Get-ADDefaultDomainPasswordPolicy** and **Get-ADFineGrainedPasswordPolicy** - length, complexity, history, and reversible-encryption settings as objects/CSV. (3.5.7, 3.5.8, 3.5.10)
- **Get-GPOReport -ReportType Xml** - password policy, NTLM restrictions, FIPS-mode, and interactive-logon settings as XML. (3.5.4, 3.5.7, 3.5.10)
- **secedit /export** - local security policy (including *ClearTextPassword = 0* and FIPS setting) to an INF text file. (3.5.10)
- **Search-ADAccount -AccountInactive -TimeSpan 90.00:00:00** - inactive-account listing as CSV; schedule it and keep the outputs. (3.5.6)
- **PingCastle / Purple Knight** - AD security posture reports flagging password-policy weaknesses, reversible encryption, and stale accounts as HTML/XLSX. (3.5.6, 3.5.7, 3.5.10)

MFA and Authenticator Inventory

- **Duo Admin API / Okta API** - enrolled factors per user and per-application MFA policy as JSON, for non-Microsoft IdPs. (3.5.3)
- **YubiKey / FIDO2 registration exports** - Entra FIDO2 key inventory via Graph; pair with the vendor's FIPS 140 certificate numbers in the SSP. (3.5.3, 3.5.10)
- **Sign-in logs (Entra / SIEM)** - KQL query showing MFA claims on interactive sign-ins, exported as CSV - proof MFA is enforced in practice, not just configured. (3.5.3, 3.5.4)

Cloud Posture (Azure, AWS, GCP)

- **AWS IAM credential report** (`aws iam get-credential-report`) - per-user MFA, key age, and password-last-used as CSV; **account password policy** via `aws iam get-account-password-policy` as JSON. (3.5.3, 3.5.6, 3.5.7)
- **Prowler / ScoutSuite / Steampipe** - multi-cloud CIS/NIST checks (MFA enforcement, password policy, stale credentials) as JSON/CSV/HTML. (broad)
- **Microsoft Defender for Cloud** - built-in NIST SP 800-171 regulatory-compliance report covering identity recommendations, exportable. (broad)

SCAP & Benchmark Scanners (authoritative, structured)

- **DISA SCAP Compliance Checker (SCC)** with Windows STIG benchmarks - validates FIPS mode, LAN Manager level, password settings, and masked-credential settings as XCCDF/OVAL/ARF XML. (3.5.4, 3.5.7, 3.5.10, 3.5.11)
- **OpenSCAP** (`oscap`) for Linux hosts - PAM password-quality and hashing configuration results as XCCDF/ARF XML. (3.5.7, 3.5.10)

- **Microsoft Security Compliance Toolkit / PolicyAnalyzer** - baseline comparisons of authentication settings exportable to XML/CSV. (3.5.7, 3.5.8)

OSCAL & Compliance Automation (the structured-format endgame)

- **OSCAL** (NIST Open Security Controls Assessment Language) - represent your SSP, components, and assessment results as JSON/XML/YAML. (all IA)
- **IBM compliance-trestle (Trestle)** - author and validate OSCAL artifacts programmatically. (all IA)

Practical tip: for every export, record what was run, on which system, and when. A traceable, dated artifact is worth far more than an undated screenshot.

Conclusion

Identification and Authentication is small in requirement count but heavy in points and assessor attention. Get the four 5-point requirements airtight first - unique identifiers everywhere, no unauthenticated access paths, MFA on every population 3.5.3 names, enforced with phishing-resistant, FIPS-validated authenticators, and cryptographically protected password storage and transmission under 3.5.10. The derived requirements then largely reduce to directory hygiene: sane password policy, disciplined identifier lifecycle, and modern protocols with the legacy ones switched off.

The July 2026 suspension of CMMC Phase 2 paused the third-party certification milestone, not the underlying obligation: NIST SP 800-171, DFARS 252.204-7012, and the Level 2 self-assessment remain fully in force. Implementing this family well is still required today.

Glossary of Acronyms

AAA	Authentication, Authorization, and Accounting
AD	Active Directory
ARF	Asset Reporting Format (SCAP results format)
CMMC	Cybersecurity Maturity Model Certification
CUI	Controlled Unclassified Information
DFARS	Defense Federal Acquisition Regulation Supplement
DIB	Defense Industrial Base
DIBCAC	Defense Industrial Base Cybersecurity Assessment Center

EAP-TLS	Extensible Authentication Protocol - Transport Layer Security
FIDO2	Fast Identity Online 2 (WebAuthn + CTAP passwordless standard)
FIPS	Federal Information Processing Standard
gMSA	Group Managed Service Account
GPO	Group Policy Object
IdP	Identity Provider
KQL	Kusto Query Language
LAPS	Local Administrator Password Solution
LDAPS	Lightweight Directory Access Protocol over SSL/TLS
MFA	Multi-Factor Authentication
NIST	National Institute of Standards and Technology
NTLM	NT LAN Manager (legacy Windows authentication protocol)
OSCAL	Open Security Controls Assessment Language
PAM	Privileged Access Management
PKI	Public Key Infrastructure
POA&M	Plan of Action and Milestones
RADIUS	Remote Authentication Dial-In User Service
SCAP	Security Content Automation Protocol
SCEP	Simple Certificate Enrollment Protocol
SCIM	System for Cross-domain Identity Management
SIEM	Security Information and Event Management
SMB	Server Message Block
SPRS	Supplier Performance Risk System
SSP	System Security Plan
STIG	Security Technical Implementation Guide
TACACS+	Terminal Access Controller Access-Control System Plus
TLS	Transport Layer Security
TPM	Trusted Platform Module
XCCDF	Extensible Configuration Checklist Description Format

About Methodical Security

Methodical Security provides resources and tooling to support Defense Industrial Base organizations through CMMC / NIST SP 800-171 assessments. Its platform, **Certalo**, works at the determination-statement level: it maps your existing documentation to each objective, flags where evidence is thin, and compresses the path to a submission-ready SSP, Assessment Report, and SPRS package. The result turns a one-time compliance scramble into a repeatable process — protecting current revenue and opening new contract eligibility.

Prepared by Methodical Security for informational purposes. Not legal advice - confirm obligations against your contract clauses and the DoD CMMC Program Office. · methodicalsecurity.com/resources